

Axiom AI Technologies

Cybersecurity Risk Assessment Summary

Risk Management Workstream | Axiom AI Case Study

Assessment Status: Complete

1. Executive Summary

Axiom AI Technologies is a fictional B2B AI/ML SaaS organization with approximately 180 employees. This risk assessment establishes a documented cybersecurity and information security risk baseline for the organization and provides risk-based inputs to the broader Axiom AI security and compliance case study.

The assessment identified **20 risks** across cloud infrastructure, customer data, AI/ML assets, application security, identity and access management, development infrastructure, endpoints, third-party services, resilience, incident response, and information security governance.

The assessment is considered complete because risk identification, analysis, treatment planning, and documentation activities have been performed. Remediation and control validation remain ongoing activities and are not prerequisites for completion of the assessment itself.

2. Assessment Scope

The assessment considered the confidentiality, integrity, and availability of Axiom AI's key information assets and technology services, including:

- AWS cloud infrastructure and identity services
- Customer databases and customer-facing SaaS applications
- AI/ML models and associated compute environments
- Application source code and CI/CD infrastructure
- API services and external interfaces
- Employee endpoints and corporate SaaS applications
- Security logging, monitoring, and vulnerability management
- Backup and recovery capabilities
- Incident response documentation and processes
- Critical third-party and vendor services
- DNS/domain services
- Security policies and ISMS documentation

The assessment focused on cybersecurity and information security risks and did not constitute a live penetration test, vulnerability scan, or technical security assessment of an actual production environment.

3. Risk Assessment Methodology

The assessment used a qualitative **5×5 likelihood and impact model** informed by:

- ISO/IEC 27001:2022
- ISO/IEC 27005 risk management principles
- NIST Cybersecurity Framework (CSF) 2.0
- NIST SP 800-30 risk assessment concepts

Likelihood	Impact
Score / Rating	Score / Rating
1 Rare	1 Insignificant
2 Unlikely	2 Minor
3 Possible	3 Moderate
4 Likely	4 Major
5 Almost Certain	5 Severe

Risk Calculation

Risk Score = Likelihood × Impact

Score Range Risk Level

1–4	Low
5–9	Moderate
10–16	High
17–25	Critical

Risk ratings are used to prioritize treatment and management attention.

4. Assessment Results

The assessment documented **20 cybersecurity and information security risks** associated with Axiom AI's assets and operating environment.

Assessment Metric	Result
Assets assessed	20
Risks identified	20
Assessment status	Complete
Primary treatment approach	Mitigation
Treatment strategies	Mitigate, Transfer, Accept
Risk lifecycle statuses	Open, In Progress, Accepted, Closed

The risk register documents the affected asset, threat, vulnerability or weakness, risk scenario, existing controls, inherent risk, treatment strategy, risk owner, target date, and residual-risk considerations.

5. Key Risk Themes

Identity and Privileged Access

Identity compromise, excessive cloud privileges, and unauthorized access to customer and technology assets represent important areas of exposure. Strong authentication, least-privilege access, privileged-access management, and recurring access reviews are important risk-reduction measures.

Cloud and Application Security

Cloud configuration, API security, application vulnerabilities, and deployment environments require continued preventive and detective controls. Configuration management, secure development practices, vulnerability management, and monitoring are important components of the treatment strategy.

Software and AI/ML Security

Axiom's source code, CI/CD pipeline, AI/ML models, and compute environments represent important technology and intellectual-property assets. Protecting these assets requires strong access controls, integrity protections, environment segregation, secure deployment processes, and monitoring.

Resilience and Recovery

Backup coverage, recovery testing, and operational resilience are necessary to reduce the potential impact of outages, ransomware, infrastructure failures, and other disruptive events.

Third-Party Risk

Critical suppliers may introduce confidentiality, availability, and operational dependencies. Vendor due diligence, contractual security requirements, risk classification, and recurring assessment are therefore important components of the risk management process.

Governance and Incident Response

Security policies, incident response procedures, evidence handling, defined responsibilities, and documented escalation processes support consistent security governance and effective response to security events.

6. Risk Treatment

The Risk Register uses a risk-based treatment approach.

Mitigate

Mitigation is the primary treatment strategy. It involves implementing or strengthening controls to reduce the likelihood and/or potential impact of a risk.

Examples include:

- Strengthening identity and access controls
- Improving cloud configuration management
- Expanding security monitoring
- Improving vulnerability management
- Enhancing backup and recovery testing
- Strengthening secure development practices

Transfer

Transfer is used where appropriate to shift a portion of risk through contractual, insurance, or third-party arrangements.

This approach is particularly relevant to selected third-party and vendor risks.

Accept

Risk acceptance may be appropriate when the remaining exposure falls within the organization's established risk tolerance and additional treatment is not justified by the expected cost or benefit.

Acceptance should be formally documented and approved by the appropriate risk owner.

7. Risk Lifecycle Status

Risk status represents the lifecycle state of treatment activity. It does **not** indicate whether the risk assessment itself is complete.

Status	Meaning
Open	Risk is documented and requires treatment activity or further action.
In Progress	Treatment or risk-reduction activity is underway.
Accepted	Remaining exposure has been formally accepted.
Closed	The associated risk condition has been addressed or eliminated.

The assessment therefore distinguishes between completing the assessment activity and continuing remediation or risk treatment activities.

8. Relationship to the Axiom AI Security Controls Assessment

The risk assessment is designed to connect directly with the previously completed **Axiom AI Security Controls Assessment**.

The controls assessment evaluated **40 controls** against:

- ISO/IEC 27001:2022
- NIST CSF 2.0
- NIST SP 800-53

The assessment documented:

- **14 Validated controls**

- **10 Controls In Progress**
- **16 Controls Not Started**
- **26 identified findings**
- **17 High findings**
- **9 Moderate findings**
- **35% control effectiveness**

These results provide important context for evaluating the risks documented in the Risk Register.

The relationship between the two workstreams is:

Risk Identification → Control Assessment → Control Gaps → Remediation → Residual Risk

The risk assessment identifies what could affect Axiom's information assets and business operations. The controls assessment evaluates whether relevant controls are effective. Control gaps identified during the assessment can therefore inform risk treatment and remediation priorities.

9. Residual Risk Considerations

Residual risk represents the exposure expected to remain after proposed treatment activities and associated control improvements have been implemented.

Residual risk should not automatically be considered eliminated simply because a treatment action has been planned.

Final residual-risk ratings should be reviewed and validated when:

- Remediation activities are completed
- Supporting evidence is available
- Controls are tested or validated
- Material changes occur to the environment
- New threats or vulnerabilities are identified
- Management reviews risk acceptance decisions

This creates an ongoing risk management lifecycle rather than a one-time assessment.

10. Recommended Next Steps

The following activities should continue after completion of the assessment:

1. Complete and evidence remediation activities associated with prioritized risks.
2. Validate the effectiveness of implemented controls.
3. Update the controls assessment when remediation evidence becomes available.
4. Review and approve risk treatment decisions through appropriate management ownership.
5. Use the documented risk landscape to inform the Axiom AI ISMS scope and control applicability.
6. Develop and maintain the Statement of Applicability as part of the ISMS implementation.
7. Integrate applicable risk requirements into business continuity, vulnerability management, incident response, and third-party risk processes.
8. Periodically review the Risk Register and update it when significant changes occur to systems, business processes, threats, or regulatory obligations.

11. Assessment Limitations

This is a simulated portfolio assessment.

The assessment does not involve:

- Live testing of Axiom AI systems
- Penetration testing
- Live vulnerability scanning
- Exploitation of vulnerabilities
- Access to production environments
- Collection of real customer information
- Real credentials or secrets
- Actual incident investigation
- Unauthorized security testing

Organizational, asset, risk, control, and business information is fictional or generalized for portfolio demonstration purposes.

12. Conclusion

The Axiom AI cybersecurity risk assessment establishes a documented risk baseline for the fictional organization and provides a structured foundation for continued security governance and improvement.

The assessment identified risks across Axiom's technology environment, information assets, development processes, third-party dependencies, resilience capabilities, and security governance.

The **assessment itself is complete**. Risk treatment, remediation, and control validation remain ongoing activities and should continue through the organization's broader security management lifecycle.

The results of this assessment will serve as an input to the next stage of the Axiom AI case study: **ISO/IEC 27001 ISMS Implementation**.

Portfolio Disclaimer

Axiom AI Technologies is a fictional organization created for portfolio demonstration purposes. The assessment methodology and artifacts are inspired by and based on real professional projects performed in cybersecurity, GRC, risk management, and ISO/IEC 27001 environments.